Università degli Studi di Modena e Reggio Emilia
Corso di laurea triennale in Informatica

Autonomia Offensiva dei Large Language Models Locali

Candidato
Giulio Cadeddu

Relatore
Prof. Mauro Andreolini

Anno Accademico
2025/2026

Ambito di Ricerca
Cybersecurity & Autonomous AI Agents

SCENARIO E EVOLUZIONE AI

Crescita della Potenza e Traguardi delle Tecnologie AI (2021-2026)

EVOLUZIONE COMPUTAZIONALE

Negli ultimi anni, la potenza dei modelli linguistici e generativi è cresciuta a ritmi esponenziali, ridefinendo i limiti dell'automazione e del ragionamento.

Dall'esplosione dei modelli multimodali fino all'emergere di agenti capaci di identificare autonomamente vulnerabilità e zero-day, l'IA ha trasformato la ricerca scientifica e la cybersecurity.

Questa rapida escalation pone sfide cruciali legate alla privacy, alla sicurezza offensiva e alla sovranità del dato.

TRAGUARDI CHIAVE DELL'AI (2021 - 2026)

- **2021** | Modellizzazione Linguistica su Scala (GPT-3)
- **2022** | Generazione Multimodale & AI Conversazionale
- **2023** | Diffusione di LLM Open-Source & Quantizzazione
- **2024** | Agenti Autonomi & Architetture MoE
- **2025** | Discovery di Zero-Day & Ingegneria Automatica
- **2026** | Autonomia Offensiva Locale & Reasoning Avanzato

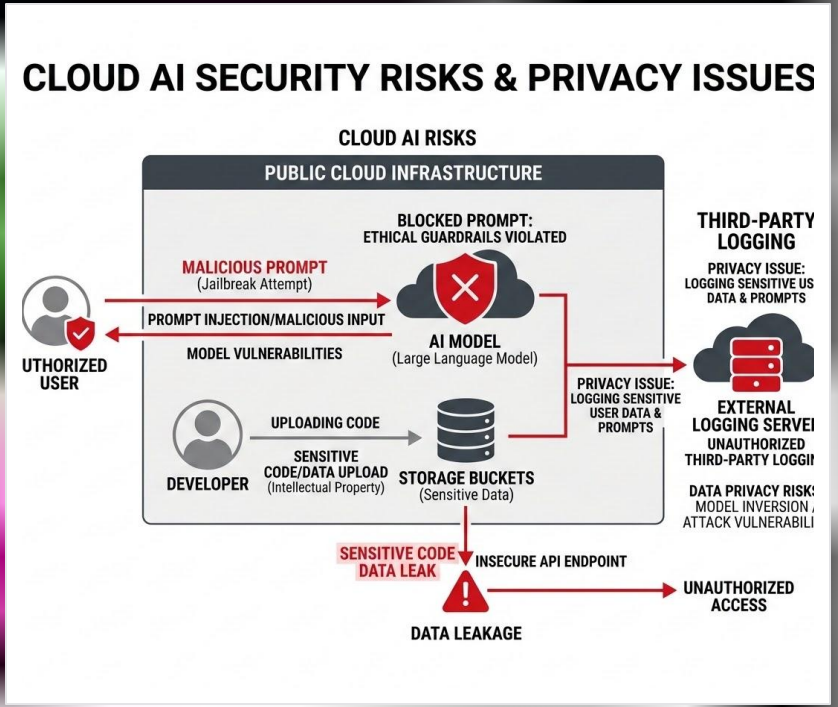
LLM nella Sicurezza Offensiva: Problemi dei Modelli Cloud

RISCHIO PRIVACY & DATA BREACH

L'invio di dati sensibili, codice sorgente proprietario, architetture di rete o log a servizi cloud espone le organizzazioni e gli utenti a rischi permanenti di data breach, riaddestramento dei modelli sui prompt e acquisizioni di dati personali da parte del provider del servizio.

GUARDRAIL ETICI & CENSURE COMMERCIALI

I filtri di sicurezza e le policy etiche dei provider cloud commerciali inibiscono la ricerca pratica sulle vulnerabilità, bloccando l'analisi e le simulazioni di attacchi offensivi.



SCELTE OPERATIVE

LLM nella Sicurezza Offensiva: Adozione di LLM locali

PRO: VANTAGGI OPERATIVI

• **Sostenibilità economica:** Azzeramento dei costi ricorrenti di abbonamento e consumo API cloud.

• **Esecuzione uncensored:** Assenza di guardrail etici per condurre test di penetrazione trasparenti.

• **Tutela della privacy:** Isolamento totale dei dati sensibili ed eliminazione dei rischi di data breach.

CONTRO: SFIDE E LIMITI TECNICI

• **Prestazioni ridotte:** Throughput di inferenza e accuratezza inferiori ai modelli di frontiera.

• **Complessità del set-up:** Elevato onere operativo per la creazione dell'infrastruttura di esecuzione.

• **Costo manutentivo:** Gestione complessa del cluster hardware e del tuning dei parametri.

OBIETTIVI DI RICERCA

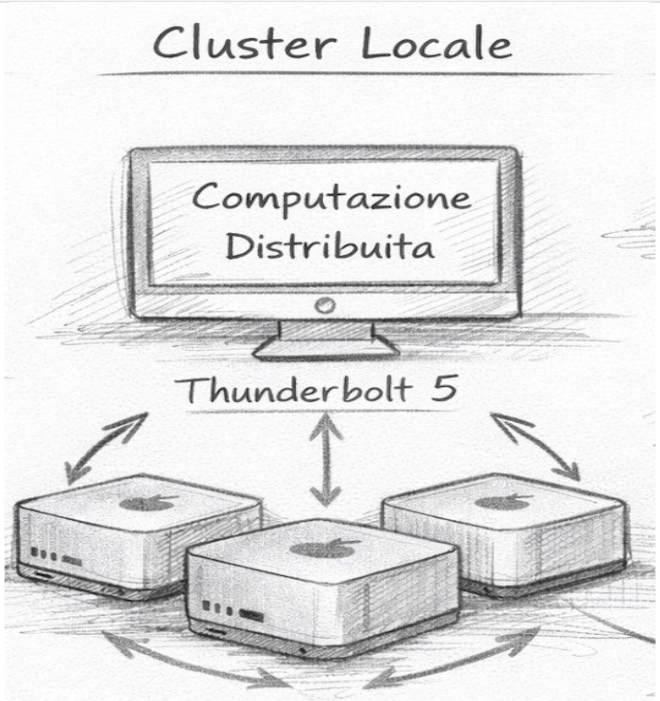
Sfide e domande di ricerca

DOMANDE DI RICERCA

• **Inferenza locale distribuita:** È possibile eseguirla su hardware consumer mantenendo tempi di risposta utili?

• **Modelli uncensored:** Un modello open-source privo di censure possiede le reali capacità logiche per orchestrare un attacco senza intervento umano?

• **Rapporto costi-benefici:** Qual è il reale bilancio economico ed operativo rispetto all'utilizzo dei modelli commerciali cloud?



APPROCCIO PROPOSTO

Limiti e scelte architetturali

INFERENZA SU CLUSTER VIRTUALE DI CPU

• Benché le GPU rappresentino la soluzione ideale per l'inferenza di LLM, i loro costi estremamente elevati ne limitano l'accessibilità.

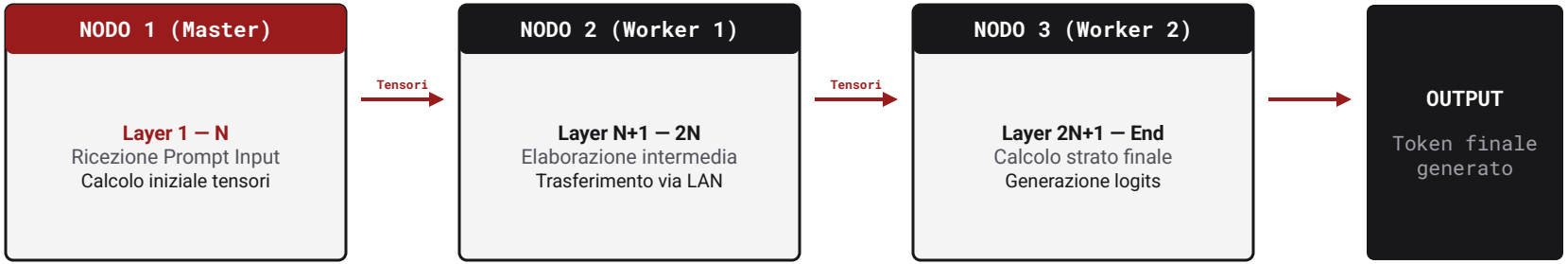
• Si è optato per un cluster virtuale di CPU su server, aggregando la RAM di più nodi per eseguire modelli di grandi dimensioni.

PIPELINE PARALLELISM (PP)

• Scomposizione sequenziale per strati (layer): i layer del modello vengono raggruppati in blocchi e assegnati a nodi hardware distinti.

• Ciascun nodo elabora la propria porzione ed invia i tensori di attivazione al nodo successivo via LAN, simulando una catena di montaggio.

FLUSSO DATI & ARCHITETTURA PIPELINE PARALLELISM



APPROCCIO PROPOSTO

Ottimizzazione e Architetture di Modelli

Modelli Quantizzati & Risparmio Memoria

• Prediligere modelli quantizzati (es. GGUF Q4) per un drastico risparmio di memoria RAM/VRAM rispetto ai pesi originali.

• Comprimere la precisione abbatte l'occupazione fino a 1/3, rendendo eseguibili reti Medium su cluster locali.

PESI ORIGINALI vs QUANTIZZATI (FASCIA MEDIUM 10B-35B)



RIDUZIONE RAM
Oltre il -65% di memoria occupata

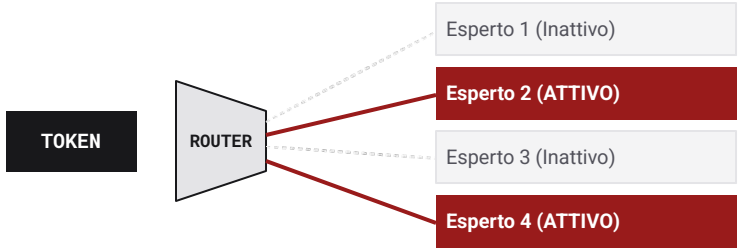
FATTIBILITÀ LOCAL
Esecuzione fluida su pochi nodi CPU

Architettura Mixture of Experts (MoE)

• Prediligere l'utilizzo di modelli MoE per un enorme risparmio di tempo nell'inferenza (tok/s).

• A differenza dei modelli densi che leggono tutti i pesi, MoE attiva unicamente gli esperti selezionati dal Router ad ogni token.

MECCANISMO DI ROUTING & ESPERTI ATTIVI



Agenti Autonomi e Profili Agentici

AGENTI AUTONOMI

• Entità attive orientate al raggiungimento di un obiettivo complesso.

• Sfruttano l'LLM come motore cognitivo centrale per pianificare e ragionare.

• Ciclo continuo di percezione, pianificazione, azione e feedback.

PROFILI AGENTICI SVILUPPATI

• **Agente 1 (Generico):** Autonomo; esplorazione libera e ReAct senza guida procedurale.

• **Agente 2 (Specifico):** Procedurale; segue una metodologia sequenziale e rigida step-by-step.

• **Agente 3 (Orchestratore):** Tooling; gestisce ed esegue strumenti di automazione CLI (es. sqlmap).

CONFRONTO OPERATIVO: LLM vs AGENTE

LLM TRADIZIONALE

PRODUCE SOLO OUTPUT TESTUALE

• Operatore passivo: genera testo statico in risposta al prompt.

• Nessuna interazione diretta con l'ambiente o con strumenti esterni.

AGENTE AUTONOMO

COMPILAZIONE DI AZIONI CONCRETE

• Operatore attivo: esegue comandi e invoca tool (shell, API, script).

• Mantiene lo stato, gestisce la memoria ed esegue autocorrezione.

VALUTAZIONE SPERIMENTALE

L'Esperimento e i Risultati

01

FASE 1: SCALABILITÀ HARDWARE

• **Test di Carico sul Cluster:** Valutazione del throughput (Tok/s) lungo la topologia distribuita.

• **Modelli Densi vs MoE:** Confronto diretto della scalabilità orizzontale e impatto della quantizzazione.

• **Identificazione Sweet Spot:** Determinazione della soglia minima di usabilità (≥ 5 tok/s).

02

FASE 2: EFFICACIA OFFENSIVA

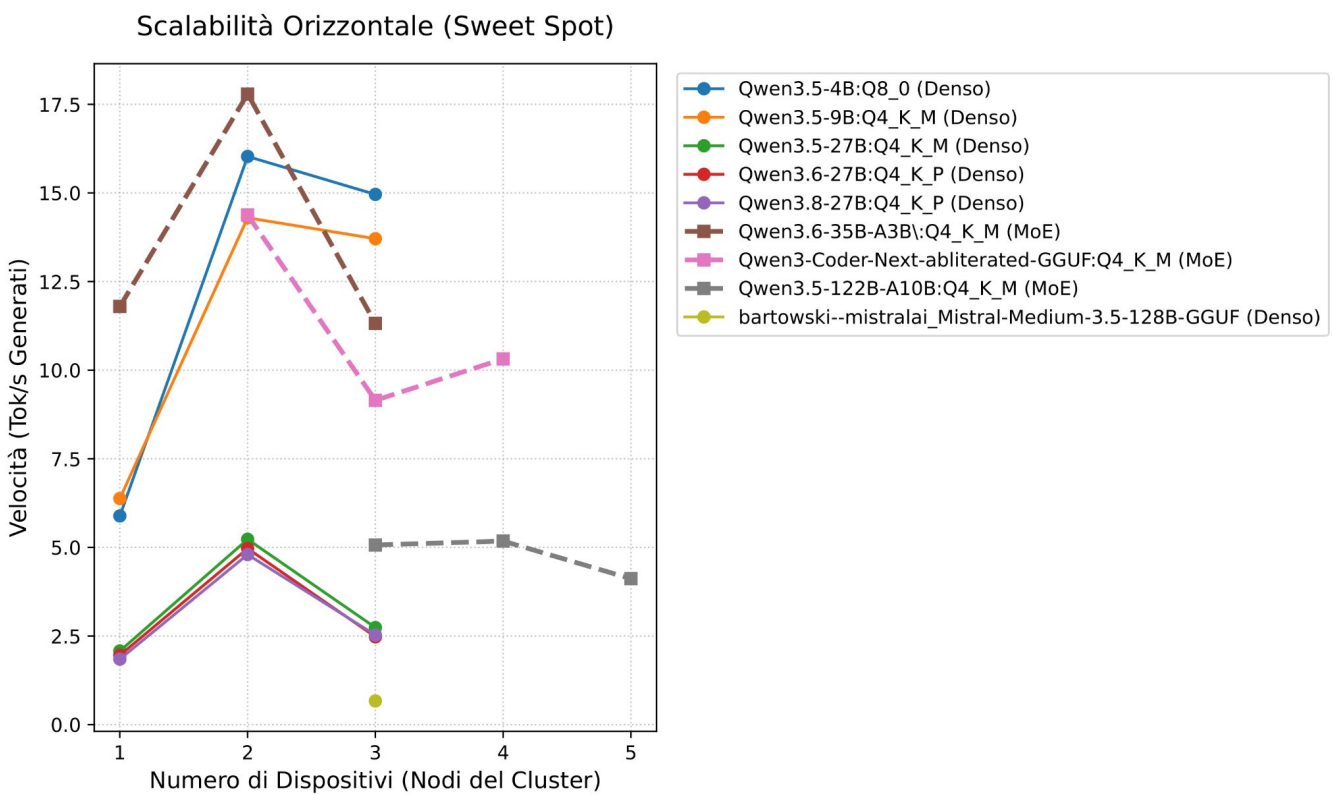
• **Ambiente Bersaglio:** Test di esfiltrazione autonoma su vulnerabilità SQL Injection (Web For Pentester).

• **Confronto Profili Agentici:** Misurazione dei tassi di risoluzione tra Agente 1 (Libero), 2 (Procedurale) e 3 (Tooling).

• **Analisi dei Fallimenti:** Tassonomia degli stalli cognitivi e valutazione della sostenibilità economica (ROI).

PROFILAZIONE HARDWARE & PERFORMANCE

Risultati prestazionali



EFFICIENZA ARCHITETTURALE MoE

• **Superiorità di Throughput:** La velocità dei modelli Mixture of Experts (MoE) supera nettamente le prestazioni dei modelli densi.

• **Attivazione Selettiva dei Pesi:** Attivando solo una frazione dei parametri per ciascun token, MoE abbatte drasticamente il carico sulla RAM.

EFFICACIA OFFENSIVA & RISULTATI

Tasso di risoluzione agenti



EFFICIENZA DELL'AGENTE 3 (TOOLING)

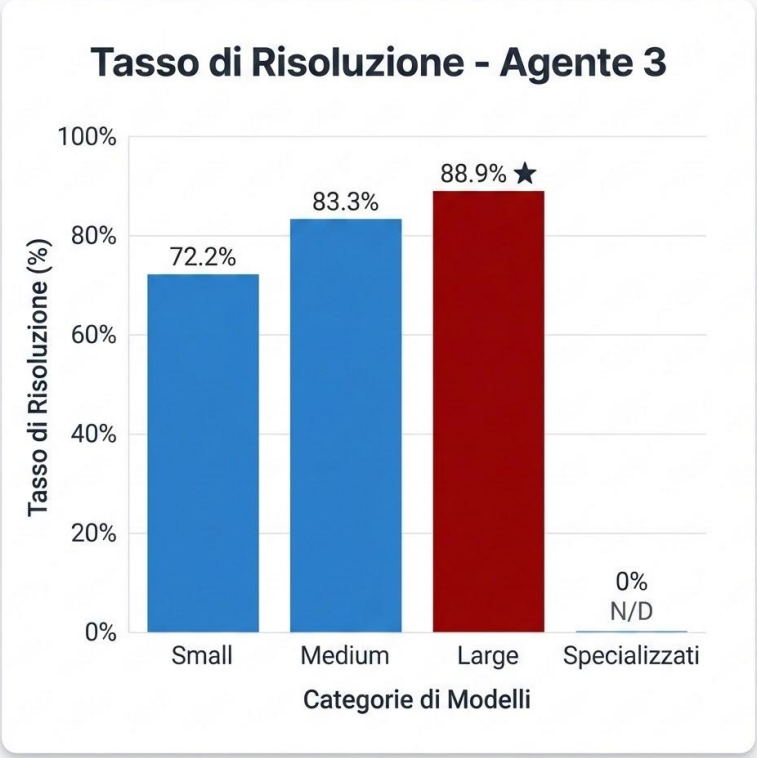
• **Netto Stacco Prestazionale:** L'Agente 3 (Tool-Assisted) ottiene un tasso di successo del **56.7%**, oltre 4 volte superiore rispetto agli agenti manuali.

• **Ruolo di Orchestratore:** I LLM massimizzano la loro efficacia quando guidano strumenti di automazione CLI (es. sqlmap), delegando il lavoro computazionale pesante.

• **Limiti dell'Invocazione Manuale:** L'Agente 1 (14.4%) e l'Agente 2 (11.1%) soffrono di frequenti stalli logici e rapida saturazione della Context Window.

EFFICACIA OFFENSIVA & RISULTATI

Tasso di successo dei Modelli



RISULTATI PER FASCIA DIMENSIONALE

• **Superiorità dell'Agente 3:** L'orchestrazione di tool eleva il successo all'**88.9%** per i modelli Large e all'**83.3%** per i Medium.

• **Efficacia nei Modelli Small:** Privati dei filtri etici, anche i modelli ridotti ottengono un significativo **72.2%** se guidati da strumenti.

• **Anomalia dei Modelli Specializzati:** Le architetture verticali (0%) falliscono sistematicamente a causa della violazione dei vincoli procedurali.

• **Esclusività per Agenti Manuali:** Negli agenti manuali (1 e 2), **solo la fascia Medium (10B-35B)** è stata in grado di risolvere con successo le challenge.

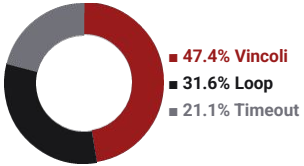
EFFICACIA OFFENSIVA & RISULTATI

Tassonomia dei Fallimenti Cognitivi e Strutturali

MODELLI SMALL (1-9B)

• **Incidenza Timeout:** Alta frequenza per timeout (**21.1%**) e vincoli (**47.4%**).

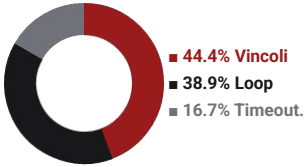
• **Saturazione Contesto:** Fatica a mantenere la coerenza in task lunghi.



MODELLI MEDIUM (10-35B)

• **Tunnel Vision:** Fissazione su vettori d'attacco errati (**38.9%**).

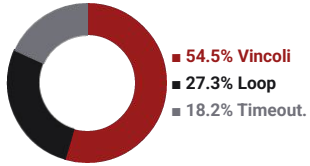
• **Elevata Capacità:** Evitano il blocco ma rischiano esaurimento passaggi.



MODELLI LARGE (>35B)

• **Insofferenza Vincoli:** Violazione regole (**54.5%**) per output troppo verbosi.

• **Verbosità Eccessiva:** Tendenza ad eludere le restrizioni strutturali.



MODELLI SPECIALIZZATI

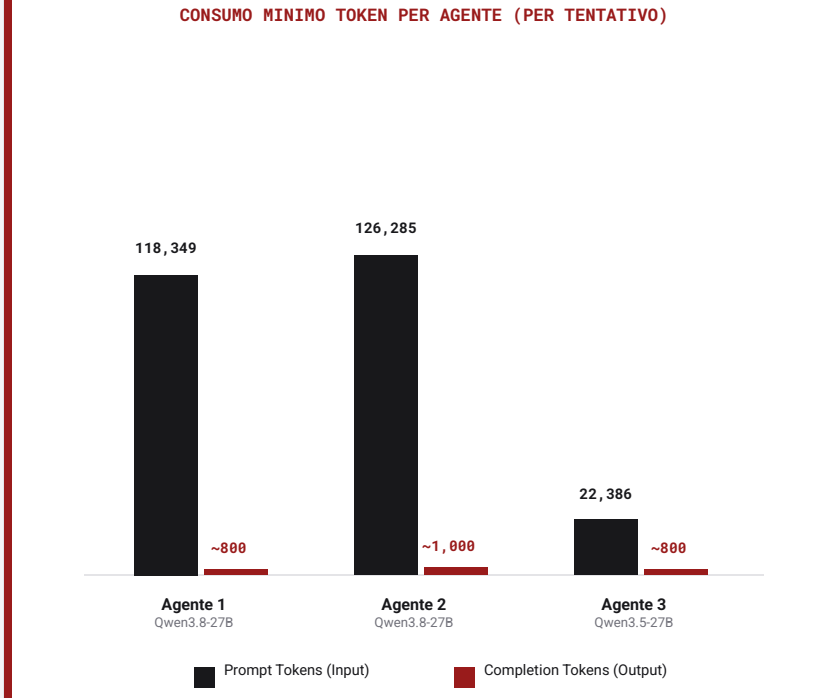
• **Refusal Totali:** Blocchi e rifiuti sistematici nell'elaborazione.

• **Violazione Vincoli:** **100%** di fallimenti per inosservanza direttive.



EFFICIENZA COMPUTAZIONALE & COSTI

Confronto Consumo Token Minimo per Agente



SOSTENIBILITÀ ED APPLICABILITÀ REALE

• **Abbattimento del Consumo:** L'uso di tool dedicati riduce drasticamente il footprint computazionale, passando dagli oltre **118.000 token** dell'Agente 1 e **126.000** dell'Agente 2 a soli **22.386 token** per l'Agente 3.

• **Prestazioni Migliori e Orchestrazione:** Delegando il parsing pesante a strumenti esterni (es. sqlmap), il LLM evita la saturazione della Context Window e si concentra esclusivamente sulla regia strategica.

• **Efficienza e Valore Aziendale:** Il drastico calo nei tempi d'esecuzione e nei costi dei token trasforma i LLM locali in un **co-pilota aziendale sostenibile** ed estremamente efficace.

Conclusioni & Sviluppi Futuri

> *"I LLM locali uncensored non possiedono ancora l'autonomia cognitiva per condurre attacchi complessi indipendentemente, ma si confermano eccellenti co-piloti se inseriti in pipeline strutturate con strumenti specialistici."*

Valutazione Autonomia Cognitiva & Pipeline Integration

Fine-Tuning vs Stazza Parametrica

La qualità del fine-tuning prevale sulla pura stazza parametrica. L'inferenza distribuita su CPU offre una soluzione sostenibile e democratizzata.

Integrazioni & Modelli MoE

Gli sviluppi futuri prevedono l'integrazione di framework come Metasploit e Nmap.

L'impiego di modelli MoE sempre più avanzati permetterà di testare scenari black-box completamente autonomi, riducendo la necessità di prompt engineering iniziale.